IEC 62443 — Siber Güvenlik İncelemesi

Analizin kapsamı

VF-1D-A-696 için analiz edilen erişim ve yapılandırma zafiyetleri, IEC 62443'ün risk değerlendirmesi ve sistem güvenliği başlıklarıyla ilişkilendirilmiştir. Odak, yetkisiz değişikliklerin SF1 güvenli erişim ve SF2 aşırı sıcaklık korumasını etkileyebildiği saldırı yollarıdır.

Başvuru çerçevesi

Referans	Kapsam	Projedeki karşılığı
IEC 62443-3-2:2020	Sistemin sınırları, zone/conduit, risk değerlendirmesi ve hedef güvenlik seviyesi	LAB 2'deki bölgeleme ve R01–R03 kayıtları
IEC 62443-3-3:2013	Sistem güvenlik gereksinimleri ve güvenlik yetenek seviyeleri	Aşağıdaki kontrol ve kanıt eşleştirmesi

Resmî kapsam açıklamaları ve önizlemeler esas alınmıştır; tablo, projeye ait gereksinim önerilerini gösterir.

Zafiyet ve kontrol eşleştirmesi

Olası zafiyet / risk	Başlık	Önerilen kontrol	İncelenecek kanıt
Ele geçirilebilir bakım hesabı — R02	FR1: Kimlik doğrulama	Kişisel hesap, MFA; bağlantı varsa süreli yetki	Hesap politikası ve bakım erişim ayarları
Operatörün emniyet parametresi yazabilmesi — R01	FR2: Kullanım kontrolü	Operatör ve mühendislik yetkilerini ayırma	Rol/yetki matrisi ve yazma izinleri
Emniyet mantığının yetkisiz değiştirilmesi — R01/R03	FR3: Sistem bütünlüğü	Onaylı yapılandırma, değişiklik kontrolü ve bütünlük doğrulaması	Sürüm/yedek bilgisi ve doğrulama kayıtları
Bakım trafiğinin korunmaması — R02	FR4: Veri gizliliği	Erişim varsa uygun şifreli iletişim	Tünel ve iletişim yapılandırması
Proses veya dış ağdan emniyete serbest geçiş — R01/R02	FR5: Kısıtlı veri akışı	Ayrı emniyet bölgesi ve yalnız gerekli geçişler	Ağ şeması ve izin kuralları
Yetkisiz değişikliğin fark edilmemesi — R01–R03	FR6: Olaylara zamanında yanıt	Güvenlikle ilgili işlem kayıtları ve uyarılar	Erişim/değişiklik logları ve uyarı tanımları
Kontrol kaybında koruyucu işlevlerin etkilenmesi — R01–R03	FR7: Kaynak kullanılabilirliği	Gerekli koruyucu işlevlerin sürekliliği ve kurtarma düzeni	Arıza davranışı, yedek ve kurtarma doğrulaması

FR başlıkları standardın genel çerçevesidir; öneriler proje analizidir. Bunlar, makinede uygulanmış kontroller olarak gösterilmemiştir.

Risk kaydıyla bağlantı

• R01: Yetki sınırları ve emniyet yapılandırmasının korunması önceliklidir.

• R02: Önce modele özel uzak bağlantının varlığı belirlenir; varsa erişim ve bölge sınırları değerlendirilir.

• R03: Servis bilgisayarı, fiziksel yapılandırma bağlantısı ve değişiklik doğrulaması ele alınır.

Risk kaydı · Önerilen bölgeler

Güvenlik seviyesi ve bilgi ihtiyacı

LAB'daki L × S × E skoru, IEC 62443 güvenlik seviyesi değildir. SL-T hedefi için bölgeye özgü ayrıntılı risk değerlendirmesi gerekir; mevcut verilerle makineye SL seviyesi atanmaz.

PLC/HMI sürümleri, hesap politikaları ve gerçek ağ şeması henüz bilinmiyor. Bu nedenle belirli bir CVE, varsayılan parola veya açık port bu modele atfedilmemiştir.

Kaynaklar

• IEC 62443-3-2:2020 — Resmî kapsam.

• IEC 62443-3-3:2013 — Resmî yayın.

• IEC — 62443 seri özeti ve FR başlıkları.

• NIST SP 800-82 Rev. 3 — OT Security: kontrol önerileri için destekleyici başvuru.

Sonuç

Siber güvenlik incelemesinde öncelik, emniyet parametrelerinin yetkisiz değiştirilememesi ve erişim yollarının sınırlandırılmasıdır. Önerilerin değerlendirilmesi, yapılandırma ve kayıt kanıtlarıyla desteklenmelidir.